



Altyn Copper Concentrator JSC — Единое руководство по внутренним процессам

Общие положения

Настоящий стандарт устанавливает базовые требования к использованию информационных систем и оборудования. Он применяется ко всем работникам и подрядчикам, получающим доступ к корпоративным ресурсам. Несоблюдение требований может повлечь ограничение доступа.

Требования настоящего стандарта распространяются на корпоративные информационные системы независимо от места их размещения, включая системы, размещённые у внешних поставщиков услуг. Владельцы систем обеспечивают соответствие требованиям при вводе систем в эксплуатацию.

Отступления от требований допускаются в исключительных случаях по письменному согласованию со службой информационной безопасности с указанием компенсирующих мер и срока действия отступления. Реестр действующих отступлений пересматривается ежеквартально.

Учётные записи и доступ

Учётная запись создаётся на основании заявки руководителя подразделения и предоставляет минимально необходимый набор прав. Права пересматриваются при изменении должности и отзываются при увольнении. Совместное использование учётных записей не допускается.

Привилегированные учётные записи выделяются отдельно от обычных и используются только для выполнения административных задач. Их применение подлежит обязательному журналированию, а перечень владельцев пересматривается ежеквартально.

Периодическая сверка прав доступа проводится совместно владельцами систем и руководителями подразделений. Права, не подтверждённые по итогам сверки, отзываются в течение пяти рабочих дней с оформлением соответствующей записи.

Пароли и многофакторная аутентификация

Пароли должны отвечать установленным требованиям к сложности и не подлежат передаче третьим лицам. Для доступа к системам, отнесённым к критичным, применяется многофакторная аутентификация. Восстановление доступа производится службой поддержки после подтверждения личности.

Хранение паролей в открытом виде, в том числе в текстовых файлах и в записках на рабочем месте, не допускается. Для хранения служебных паролей применяется корпоративное хранилище с разграничением доступа.

Компрометация или подозрение на компрометацию пароля является основанием для его немедленной смены и уведомления службы поддержки. При компрометации привилегированной учётной записи проводится дополнительный анализ журналов за предшествующий период.

Рабочие станции и мобильные устройства

Рабочие станции комплектуются штатным программным обеспечением; установка стороннего программного обеспечения выполняется по согласованию. Мобильные устройства, используемые для работы, подлежат регистрации. Стоимость стандартного комплекта рабочего места составляет 715 480 тенге.

На рабочих станциях применяются средства защиты от вредоносного программного обеспечения с автоматическим обновлением. Отключение средств защиты пользователем не предусмотрено; временное отключение выполняется только специалистом службы поддержки.

Утрата устройства, содержащего служебную информацию, подлежит немедленному уведомлению службы поддержки для дистанционной блокировки. Расследование обстоятельств утраты проводится в общем порядке рассмотрения инцидентов.

Электронная почта и обмен сообщениями

Корпоративная почта используется для служебной переписки. Пересылка служебной информации на личные адреса не допускается. При получении подозрительного сообщения работник сообщает в службу поддержки и не открывает вложения.

Массовые рассылки внешним адресатам согласуются с подразделением, отвечающим за коммуникации. Использование корпоративного адреса для регистрации в сторонних сервисах, не связанных с работой, не допускается.

Служебная переписка, содержащая сведения ограниченного распространения, направляется с применением предусмотренных средств защиты. Пересылка таких сведений через публичные мессенджеры не допускается.

Резервное копирование

Резервные копии критичных систем создаются по установленному расписанию и хранятся в отдельном сегменте. Восстановление проверяется по плану тестирования не реже одного раза в полугодие. Результаты проверок оформляются протоколом.

Перечень систем, подлежащих резервному копированию, и глубина хранения копий определяются владельцами систем с учётом требований к непрерывности деятельности. Перечень пересматривается ежегодно.

Носители резервных копий, выводимые из обращения, подлежат гарантированному удалению данных. Доступ к хранилищу резервных копий предоставляется ограниченному кругу лиц и подлежит журналированию.

Управление изменениями

Изменения в промышленных системах вносятся через процедуру управления изменениями с указанием причины, плана работ и плана отката. Плановые окна согласуются с владельцами систем. Экстренные изменения оформляются постфактум в течение одного рабочего дня.

Изменения классифицируются как стандартные, обычные и экстренные. Стандартные изменения выполняются по заранее согласованным процедурам без дополнительного согласования; обычные требуют согласования владельцем системы.

После внесения изменения проводится проверка работоспособности по согласованному перечню проверок. При отрицательном результате выполняется откат в соответствии с планом, а причины анализируются на ближайшем совещании.

Мониторинг и журналирование

События информационной безопасности фиксируются в централизованной системе журналирования. Срок хранения журналов определяется внутренними требованиями. Доступ к журналам предоставляется ограниченному кругу лиц.

Перечень событий, подлежащих регистрации, включает попытки аутентификации, изменения прав доступа, действия привилегированных учётных записей и изменения конфигурации средств защиты.

Целостность журналов обеспечивается ограничением прав на изменение и регулярной выгрузкой в отдельное хранилище. Анализ журналов выполняется по установленному регламенту и по запросу в рамках расследований.

Реагирование на инциденты

Инцидент регистрируется по факту обнаружения и классифицируется по степени критичности. Дежурный инженер принимает первичные меры и при необходимости эскалирует обращение. Разбор по завершении инцидента проводится без поиска виновных.

Для каждого класса инцидентов определены целевые сроки реакции и восстановления. Ход работы фиксируется в системе учёта обращений; переписка по инциденту ведётся в одной ветке.

По итогам инцидентов высокой критичности готовится отчёт, содержащий хронологию, влияние, первопричину и перечень мер. Отчёт направляется владельцам затронутых систем и хранится в общем каталоге.

Работа с подрядчиками и доступ извне

Удалённый доступ подрядчиков предоставляется на ограниченный срок и только к согласованным ресурсам. Действия подрядчиков подлежат журналированию. По завершении работ доступ отзывается в течение одного рабочего дня.

До предоставления доступа с подрядной организацией заключается соглашение о конфиденциальности. Перечень предоставленных доступов ведётся службой информационной безопасности.

Работы, выполняемые подрядчиком в промышленной среде, проводятся в согласованные окна и, при высокой критичности системы, в присутствии ответственного работника заказчика.

Утилизация оборудования и носителей

Оборудование, выводимое из эксплуатации, подлежит гарантированному удалению данных. Носители, не подлежащие повторному использованию, уничтожаются с оформлением акта. Годовые расходы на утилизацию оцениваются в 1 143 800 тенге.

Оборудование, передаваемое между подразделениями, подлежит очистке от данных предыдущего пользователя. Передача без очистки допускается только внутри одного подразделения с согласия владельца данных.

Акты об уничтожении носителей хранятся вместе с учётными карточками оборудования. Сверка фактического наличия оборудования с данными учёта проводится не реже одного раза в год.

Обучение и осведомлённость

Работники проходят вводное обучение при приёме и периодическое обучение по вопросам информационной безопасности. Материалы размещаются в корпоративном каталоге. Учёт прохождения обучения ведёт служба персонала.

Программа осведомлённости включает регулярные информационные рассылки и учебные проверки устойчивости к фишингу. Результаты проверок используются обезличенно и служат основанием для корректировки программы.

Работники, чьи обязанности связаны с обработкой сведений ограниченного распространения, проходят дополнительное обучение. Перечень таких должностей согласуется со службой информационной безопасности.

Назначение и область применения

Настоящий документ определяет порядок выполнения работ подразделениями и распространяется на все площадки, находящиеся под операционным управлением. Он подлежит пересмотру не реже одного раза в год, а также при существенном изменении организационной структуры. Руководители подразделений обеспечивают ознакомление работников с его положениями под роспись.

Положения настоящего документа применяются с учётом особенностей конкретных площадок, определённых приложениями к нему. При расхождении между настоящим документом и приложением приоритет имеет приложение в части, прямо им урегулированной. Руководитель площадки вправе устанавливать дополнительные требования, не противоречащие настоящему документу, оформляя их отдельным распоряжением.

Владельцем процесса является служба операционного управления. Она ведёт реестр действующих редакций, обеспечивает их доступность в общем каталоге и организует ежегодный пересмотр. Ознакомление вновь принятых работников проводится в течение первой рабочей недели и фиксируется в журнале ознакомления.

Роли и ответственность

Руководитель площадки отвечает за общую организацию работ и распределение ресурсов. Дежурный диспетчер ведёт оперативный журнал и передаёт смену в установленном порядке. Специалист по охране труда проводит вводные и повторные инструктажи. Ответственность за ведение записей возлагается на лицо, назначенное приказом по подразделению.

Распределение обязанностей между работниками закрепляется в должностных инструкциях и не может противоречить настоящему документу. При временном отсутствии ответственного лица его обязанности возлагаются на замещающего работника приказом по подразделению; передача обязанностей без оформления не допускается.

Матрица ответственности пересматривается при изменении организационной структуры, а также по итогам разбора происшествий, если разбор выявил неопределённость в распределении обязанностей. Актуальная матрица размещается на информационном стенде площадки и в общем каталоге подразделения.

Планирование работ и сменность

График работ формируется на месяц вперёд и доводится до сведения работников не позднее чем за десять дней до начала периода. Изменения в графике согласуются с руководителем подразделения. Продолжительность смены и порядок предоставления перерывов определяются правилами внутреннего трудового распорядка.

Планирование учитывает прогнозируемые объёмы, доступность оборудования и плановые остановки. Заявки подразделений на включение работ в график подаются не позднее двадцатого числа месяца, предшествующего планируемому. Заявки, поданные позже, включаются в график только при наличии резерва мощности.

Сверхурочные работы и работа в выходные дни допускаются в исключительных случаях с письменного согласия работника и оформляются в порядке, установленном трудовым законодательством. Учёт рабочего времени ведётся в электронной системе; корректировки вносятся только ответственным работником службы персонала.

Приёмка и передача смены

Передача смены оформляется записью в журнале с указанием состояния оборудования, незавершённых работ и выявленных отклонений. Принимающая смена проводит осмотр рабочих мест и подтверждает приёмку подписью. Спорные вопросы разрешаются с участием руководителя подразделения.

Перед передачей смены проводится обход рабочих мест с проверкой состояния ограждений, освещения, средств пожаротушения и наличия материалов на смену. Выявленные несоответствия устраняются до передачи либо, если устранение невозможно, фиксируются с указанием срока и ответственного.

Журнал передачи смены хранится на рабочем месте диспетчера и заполняется чернилами; исправления заверяются подписью. Электронная копия формируется еженедельно и передаётся в общий каталог подразделения. Записи журнала используются при разборе происшествий как первичный источник сведений.